

法的思路写出来。这样才能够为下次遇到类似问题提供良好的支持。

(5) 系统目前达到的水平、现状、存在的问题及解决方案。第(4)部分是对已经解决的问题进行描述，而这一部分则是在前面的基础上进行提升。总结性地评价系统目前达到的水平，并对该系统的现状进行分析，指出还存在的问题，以及预期的解决方案，并说明现有系统未能有效解决问题的原因与限制。

(6) 项目总结。最后，在以上所有信息的基础上，做出客观、有效、总结性的描述，以便有关人员能够更好地了解项目的总体情况。

(7) 注解。包含有助于理解技术报告的一般信息，例如，背景信息、词汇表、原理等。这一部分应包含理解技术报告所需要的术语和定义，所有缩略词和它们在技术报告中的含义的字母序列表。

(8) 附录。提供那些为便于维护技术报告而单独编排的信息（例如，图表、分类数据等）。为便于处理，附录可以单独装订成册，按字母顺序编排。

8.9.4 项目开发总结报告

项目开发总结报告的编制，是为了总结项目开发工作的经验，说明实际取得的开发结果，以及对整个开发工作各方面的评价。根据 GB/T 8567—2006 的规定，项目开发总结报告应该包括以下几部分内容：

(1) 引言。包括项目开发总结报告的标识（包括标识号、标题、缩略词语、版本号、发行号）、系统概述、文档概述等方面的内容。

(2) 引用文件。列出项目开发总结报告引用的所有文档的编号、标题、修改版本和日期。

(3) 实际开发结果。对已经完成的工作进行概要性的总结，通常可以包括以下部分：产品、主要功能和性能、基本流程、进度、费用等。

(4) 开发工作评价。针对开发工作的情况进行简要性的评价，主要包括以下几个方面：对生产效率的评价、对产品质量的评价、对技术方法使用情况的评价、出错原因分析、风险管理等。

(5) 缺陷与处理。分别列出在需求评审阶段、设计评审阶段、代码测试阶段、系统测试阶段和验收测试阶段发生的缺陷及处理情况。

(6) 经验与教训。这是项目开发总结报告中最有价值的部分，列出从本次开发中获得的主要经验与教训，以及对今后的项目开发工作的建议。

(7) 注解。包含有助于理解项目开发总结报告的一般信息，例如，背景信息、词汇表、原理等。这一部分应包含理解项目开发总结报告所需要的术语和定义，所有缩略词和它们在项目开发总结报告中的含义的字母序列表。

(8) 附录。提供那些为便于维护项目开发总结报告而单独编排的信息（例如，图表、分类数据等）。为便于处理，附录可以单独装订成册，按字母顺序编排。

第9章 信息安全

随着信息化进程的深入和互联网的快速发展，网络化已经成为企业信息化的发展大趋势，信息资源也得到最大程度的共享。但是，紧随信息化发展而来的网络安全问题日渐突出，已成为信息时代人类共同面临的挑战。目前，危害计算机信息系统安全的事件频繁发生，而且有愈演愈烈之势，甚至会影响国家之间的战争形势，由既有战争方式转变为没有硝烟的网络战争。

如果计算机和网络系统的安全受到危害，将会危及国家安全，引起社会混乱，造成重大损失。系统分析师作为信息系统建设的挑大梁者，必须掌握系统安全知识，在进行系统分析与设计时，足够重视安全性分析，根据系统的环境约束和用户要求，结合当前技术的发展，为信息系统构筑“铜墙铁壁”，确保用户应用和数据的安全。

9.1 信息系统安全体系

对于一个信息系统网络，必须要从总体上进行规划，建立一个科学而全面的信息安全保障体系，从而实现信息系统的整体安全。一个全面的信息系统安全体系包含的内容是多方面的，应该能够解决信息系统存在的大部分安全威胁。目前，信息安全威胁主要有以下几个方面：

(1) 对系统稳定性和可靠性的破坏行为，包括从外部网络针对内部网络的攻击入侵行为和病毒破坏等。

(2) 大量信息设备的使用、维护和管理问题，包括违反规定的计算机、打印机和其他信息基础设施滥用，以及信息系统违规使用软件和硬件的行为。

(3) 知识产权和内部机密材料等信息存储、使用和传输的保密性、完整性和可靠性存在可能的威胁，其中尤其以信息的保密性存在威胁的可能性最大。

1. 系统安全分类

信息系统的安全是一个复杂的综合体，涉及系统的方方面面，主要包括实体安全、运行安全、信息安全和人员安全等几个部分。

(1) 实体安全。在信息系统中，计算机及相关设备、设施（含网络）统称为系统的实体。实体安全是指保护计算机设备、设施和其他媒体免遭地震、水灾、火灾、有害气体和其他环境事故（例如，电磁辐射等）破坏的措施和过程。实体安全又可分为环境安全、设备安全和媒体安全三个方面。

(2) 运行安全。运行安全包括系统风险管理、审计跟踪、备份与恢复、应急等4个方面的内容。运行安全是计算机信息系统安全的重要环节，其实质是保证系统的正常运行，不因偶然的或恶意的侵扰而遭到破坏，使系统可靠、连续地运行，服务不受中断。

(3) 信息安全。信息安全是指防止系统中的信息被故意或偶然的非法授权访问、更改、破坏或使信息被非法系统识别和控制等。简单地说，信息安全就是确保信息的保密性、完整性、

可用性和可控性。针对信息存在的形式和特点，信息安全可分为操作系统安全、数据库安全、网络安全、病毒防护、访问控制、数据加密和认证（鉴别）7个方面。

（4）人员安全。人员安全主要包括计算机使用人员的安全意识、法律意识和安全技能等。

2. 系统安全体系结构

作为全方位的、整体的系统安全防范体系也是分层次的，不同层次反映了不同的安全问题，根据网络的应用现状和结构，可以将安全防范体系划分为物理层安全、操作系统安全、网络安全、应用安全和安全管理。

（1）物理层安全。物理层的安全包括通信线路、物理设备和机房的安全等。物理层的安全主要体现在通信线路的可靠性、软硬件设备的安全性、设备的备份、防灾害能力、防干扰能力、设备的运行环境和不间断电源保障等。

（2）操作系统安全。系统层的安全问题来自计算机网络内使用的操作系统的安全。主要表现在3个方面，一是由操作系统本身的缺陷带来的不安全因素，主要包括身份认证、访问控制和系统漏洞等；二是操作系统的安全配置问题；三是病毒对操作系统的威胁。

（3）网络安全。网络层的安全问题主要体现在计算机网络方面，包括网络层身份认证、网络资源的访问控制、数据传输的保密与完整性、远程接入的安全、域名系统的安全、路由系统的安全、入侵检测的手段和网络设施防病毒等。

（4）应用安全。应用层的安全问题主要由提供服务所采用的应用软件和数据的安全性产生，包括Web服务、电子邮件系统和DNS等。此外，还包括病毒对系统的威胁。

（5）安全管理。安全管理包括安全技术和设备的管理、安全管理制度、部门与人员的组织规则等。管理的制度化极大程度地影响着整个计算机网络的安全，严格的安全管理制度、明确的部门安全职责划分与合理的人员角色配置，都可以在很大程度上降低其他层次的安全漏洞。

3. 安全保护等级

《计算机信息系统 安全保护等级划分准则》（GB 17859—1999）规定了计算机系统安全保护能力的5个等级，即用户自主保护级、系统审计保护级、安全标记保护级、结构化保护级和访问验证保护级。系统安全保护能力随着安全保护等级的提高逐渐增强。

（1）用户自主保护级（第一级）。第一级的计算机信息系统可信计算机通过隔离用户与数据来实现，使用户具备自主安全保护的能力。它具有多种形式的控制能力，对用户实施访问控制，即为用户提供可行的手段，保护用户和用户组信息，避免其他用户对数据的非法读写与破坏。第一级适用于普通内联网用户。

（2）系统审计保护级（第二级）。与第一级相比，第二级的计算机信息系统可信计算机实施了粒度更细的自主访问控制，它通过登录规程、审计与安全性相关事件和隔离资源，使用户对自己的行为负责。第二级适用于通过内联网或互联网进行商务活动，需要保密的非重要单位。

（3）安全标记保护级（第三级）。第三级的计算机信息系统可信计算机具有系统审计保护级的所有功能。此外，还提供有关安全策略模型、数据标记以及主体对客体强制访问控制的非形式化描述；具有准确地标记输出信息的能力；消除通过测试发现的任何错误。第三级适用于地

方各级国家机关、金融机构、邮电通信、能源与水源供给部门、交通运输、大型工商与信息技术企业、重点工程建设等单位。

(4) 结构化保护级（第四级）。第四级的计算机信息系统可信计算机建立于一个明确定义的形式化安全策略模型之上，它要求将第三级系统中的自主和强制访问控制扩展到所有主体与客体。此外，还要考虑隐蔽通道。本级的计算机信息系统可信计算机必须结构化为关键保护元素和非关键保护元素。计算机信息系统可信计算机的接口也必须明确定义，使其设计与实现能经受更充分的测试和更完整的复审。加强了鉴别机制，支持系统管理员和操作员的职能，提供可信设施管理，增强了配置管理控制。系统具有相当的抗渗透能力。第四级适用于中央级国家机关、广播电视部门、重要物资储备单位、社会应急服务部门、尖端科技企业集团、国家重点科研机构和国防建设等部门。

(5) 访问验证保护级（第五级）。第五级的计算机信息系统可信计算机满足访问监控器需求。访问监控器仲裁主体对客体的全部访问。访问监控器本身是抗篡改的，而且必须足够小，能够分析和测试。为了满足访问监控器需求，计算机信息系统可信计算机在其构造时，排除了那些对实施安全策略来说并非必要的代码；在设计和实现时，从系统工程角度将其复杂性降低到最小程度。支持安全管理员职能；扩充审计机制，当发生与安全相关的事件时发出信号；提供系统恢复机制。系统具有很高的抗渗透能力。第五级适用于国防关键部门和依法需要对计算机信息系统实施特殊隔离的单位。

4. 系统安全保障系统

针对当前复杂、技术手段各异的系统安全威胁，要建立一个完整的系统安全保障体系，应该包含以下几个方面的内容：

(1) 建立统一的身份认证体系。身份认证是信息交换最基础的要素，如果不能确认交换双方的实体身份，那么系统安全就根本无从得到保证。身份认证的含义是广泛的，其泛指一切实体的身份，包括人、计算机、设备和应用程序等，只有确认了所有这些信息在存储、使用和传输过程中可能涉及的实体，系统的安全性才有可能得到基本保证。

(2) 建立统一的安全管理体系。建立对所有实体有效的管理体系，能够对计算机网络系统中的所有计算机、输出端口、存储设备、网络、应用程序和其他设备进行有效的集中管理，从而有效管理和控制计算机网络中存在的安全风险。安全管理体系的建立主要集中在技术性系统的建立上，同时，也应该建立相应的管理制度，才能使安全管理系统得到有效实施。

(3) 建立规范的安全保密体系。信息的保密性是一个大型信息应用网络不可缺少的需求，所以，必须建立符合规范的信息安全保密体系，这个体系不仅应该提供完善的技术解决方案，也应该建立相应的信息保密管理制度。

(4) 建立完善的网络边界防护体系。重要的计算机网络一般会与 Internet 进行一定程度的分离，在内部信息网络和 Internet 之间存在一个网络边界。必须建立完善的网络边界防护体系，使得内部网络既能够与外部网络进行信息交流，同时也能防止从外网发起的对内部网络的攻击等安全威胁。

此外，从国家角度考虑，要加快信息系统安全立法，建立信息安全法制体系，这样才能做